

ICS 33.060.99
CCS M36

YD

中华人民共和国通信行业标准

YD/T ××××—××××

IPv6 网络安全测评方法

IPv6 network security evaluation method

××××-××-××发布

××××-××-××实施

中华人民共和国工业和信息化部 发布

目 次

前 言..... 3

1 范围..... 4

2 规范性引用文件..... 4

3 术语和定义..... 4

4 缩略语..... 4

5 安全风险分析..... 5

5.1 概述..... 5

5.2 过渡机制安全风险..... 6

5.3 IPv6 引入的安全风险..... 6

5.4 安全设备面临的新风险..... 6

6 安全测评内容..... 6

6.1 双栈安全防护能力测评..... 6

6.2 IPv6 协议安全测评..... 7

6.3 IPv6 DDoS 防护能力测评..... 9

6.4 安全配置测评..... 10

6.5 漏洞扫描测评..... 11

6.6 组网安全测评..... 12

前 言

本文件按照 GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国移动通信集团有限公司、中兴通讯股份有限公司、新华三技术有限公司、北京天融信网络安全技术有限公司、国家计算机网络应急技术处理协调中心。

本标准主要起草人：杜海涛、邵京、王悦、李伟、张峰、何申、栗栗、林兆骥、万晓兰、王龔、陈桂文、石磊、梁业裕。

IPv6 网络安全测评方法

1 范围

本文件规定了IPv6网络的安全测评内容和方法，包括双栈安全防护能力、协议安全、安全防护、安全配置、漏洞扫描、组网安全等方面，可作为IPv6规模部署中网络安全的基本测试评价方法。

本文件适用于通信网络、业务系统和支撑系统等典型网络和设备的IPv6网络安全测评。

2 规范性引用文件

本文件没有规范性引用文件。

3 术语和定义

本文件没有需要界定的术语和定义。

4 缩略语

下列缩略语适用于本文件。

ACL	访问控制列表	Access Control List
CNVD	国家信息安全漏洞共享平台	China National Vulnerability Database
CVD	通用漏洞披露	Common Vulnerabilities & Exposures
DDoS	分布式拒绝服务攻击	Distributed Denial of Service
DHCP	动态主机配置协议	Dynamic Host Configuration Protocol
IDS	入侵检测系统	Intrusion Detection System
IPS	入侵防御系统	Intrusion Prevention System
NAT	网络地址转换	Network Address Translation
ND	邻居发现	Neighbor Discovery
NDP	邻居发现协议	Neighbor Discovery Protocol
URPF	单播反向路由查找	Unicast Reverse Path Forwarding
WAF	Web应用防护系统	Web Application Firewall
XSS	跨站脚本攻击	Cross Site Script Attack

5 安全风险分析

5.1 概述

典型的企业 IPv6 网络如图 1 所示，由交换机、路由器等基础网络设备，以及防火墙、DDoS 防护设备、WAF、IDS/IPS 等安全防护设备组成。

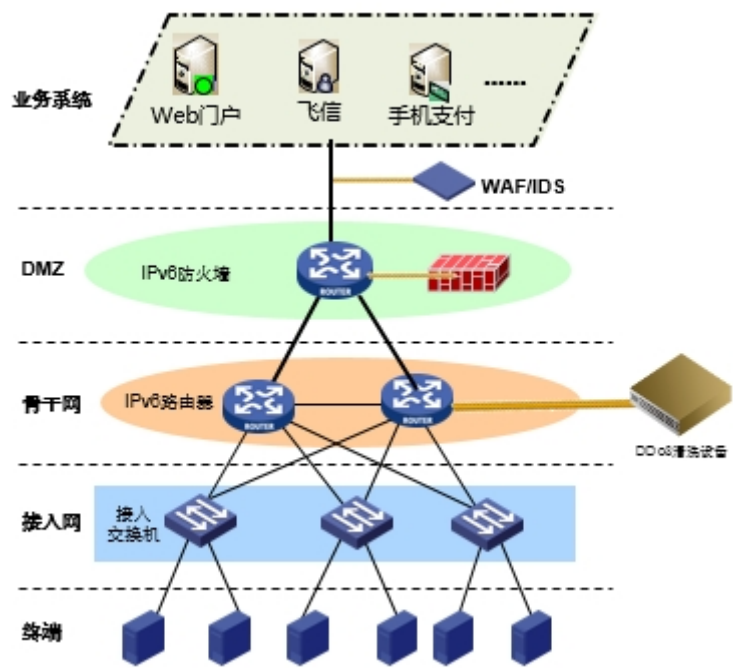


图 1 典型 IPv6 网络组成

与 IPv4 相比，IPv6 在协议方面进行了安全增强，但仍在以下三个方面存在安全风险：一是 IPv4 与 IPv6 实施的双栈配置等过渡期的安全风险；二是 IPv6 协议所引入的安全风险；三是安全防护设备面临新的安全风险。

本章节的安全风险，参考了 ITU-T X.1037 中的安全风险描述。

5.2 过渡机制安全风险

在从 IPv4 向 IPv6 过渡的过程中，“双栈”、“隧道”、“翻译”是三种可能采用的方案，均可能引入新的安全威胁。如过渡期间双栈部署的网络中同时运行着 IPv4、IPv6 两个逻辑通道，增加了设备/系统的暴露面，也意味着防火墙、安全网关等防护设备需同时配置双栈策略，从而导致策略管理的复杂度增加，安全防护被穿透的机会增加。

5.3 IPv6 引入的安全风险

IPv6 报文结构中引入的新字段（如流标签等）、IPv6 协议族中引入的新协议（如邻居

发现协议等）可能存在漏洞，这些漏洞被利用后可发起地址欺骗、DDoS 等攻击。IPv6 协议特有的攻击风险包括：逐跳扩展头攻击、邻居发现协议攻击等。

5.4 安全设备面临的新风险

过渡阶段的 IPv4 和 IPv6 双栈机制，使得同一设备至少具有 IPv4 和 IPv6 两个地址，增加了 IP 地址暴露的风险，同时也对安全设备的配置管理和扫描设备的性能都提出了更高的要求，具体如下：

- a) 网络层防护设备：在 IPv4 与 IPv6 混合网络中，防火墙/安全网关等防护设备需要同时配置双栈策略保障安全性，对设备的功能、性能的要求更高。
- b) 应用层安全防护设备：WAF、IPS、IDS 等应用层安全防护设备的 IPv6 报文解析能力、IPv6 地址格式配置（如黑白名单等）功能可能不完善；包含安全功能的网络系统（如流量控制系统等）也可能存在类似风险。
- c) 网络扫描类设备：在 IPv4 环境下，系统漏洞扫描、WEB 漏洞扫描等设备一般按照 C 段/B 段地址进行扫描。但 IPv6 地址长达 128 位，是 IPv4 的 2^{96} 倍，扫描设备难以按照地址段实施大规模扫描。

6 安全测评内容

6.1 双栈安全防护能力测评

6.1.1 双栈安全防护配置测评

测评项	双栈设备的安全防护配置	
测评对象	网络设备/安全设备	
测评方法	检查网络单元中 IPv4 和 IPv6 双栈的基础网络设备(交换机、路由器、负载均衡等)和安全设备（防火墙等）的配置。	
测评内容	针对 IPv4 和 IPv6 协议栈,设备都具备安全相关的功能,支持进行相关的配置	是 ☐ 否 ☐
	针对 IPv4 和 IPv6 协议栈,设备都启用了安全相关的功能,并进行了相关配置	是 ☐ 否 ☐

6.1.2 双栈安全防护能力测评

测评项	双栈安全防护能力
测评对象	网络设备/安全设备
测评方法	检查网络单元中 IPv4 和 IPv6 双栈的基础网络设备(交换机、路由器、负

	载均衡等)和安全设备(防火墙等)的工作情况	
测评内容	设备启动了针对双栈的安全功能和配置后,设备仍能够正常工作,并且满足功能和性能的要求	是 ☐ 否 ☐

6.2 IPv6 协议安全测评

6.2.1 NDP 协议攻击防护能力测评

测评项	NDP 协议攻击防护能力	
测评对象	网络设备/安全设备	
测评方法	检查网络单元中基础网络设备(交换机、路由器、负载均衡等)和安全设备(防火墙等)配置	
测评内容	支持主机 ND 表项绑定记录功能,通过收集主机 ND 表项记录合法主机地址、接口、MAC 对应关系,保证合法主机的链路可达性	是 ☐ 否 ☐
	支持端口 ND 表项限制功能,通过限制设备对某端口 ND 表项的数量来缓解洪范攻击	是 ☐ 否 ☐
	支持静态 ND 表项绑定功能,通过绑定主机与 ND 之间的映射关系,防止动态地址欺骗攻击对 ND 表项进行篡改	是 ☐ 否 ☐

6.2.2 地址欺骗防护能力测评

测评项	地址欺骗防御能力	
测评对象	三层路由交换设备	
测评方法	检查三层路由设备 DHCP 配置	
测评内容	支持通过配置端口 ACL,对连接终端主机的接口收到的 DHCP 应答消息进行过滤,实现只接收与真实 DHCP 服务器互联接口收到的 DHCP 应答消息,避免从非信任接口遭受 DHCP 欺骗	是 ☐ 否 ☐
	支持 DHCP Guard 功能,对连接终端主机的接口收到的 DHCP 应答消息进行过滤,实现只接收与真实 DHCP 服务器互联接口收到的 DHCP 应答消息,避免从非信任接口遭受 DHCP 欺骗	是 ☐ 否 ☐
	支持通过配置端口 ACL,对连接终端主机的接口收到的 RA 应答消息进行过滤,实现只接收与真实路由器互联接口收到的 RA 应答消息,避免从非信任接口遭受 RA 欺骗	是 ☐ 否 ☐
	支持 RA Guard 功能,对连接终端主机的接口收到的 RA 应答消息进行过滤,实现只接收与真实路由器互联接口收到的 RA 应答消息,避免从非信任接口遭受 RA 欺骗	是 ☐ 否 ☐

6.2.3 URPF 功能测评

测评项	URPF 功能	
测评对象	三层路由交换设备	
测评方法	检查网络单元中三层路由交换设备配置	
测评内容	支持 URPF 配置功能	是 ☐ 否 ☐
	开启配置 URPF, 转发设备根据报文源地址查询本地路由表, 若发现本地没有对应的路由, 或报文的入接口与路由的出接口不符, 则判断该报文来源不合法, 进行丢弃处理	是 ☐ 否 ☐

6.2.4 扩展头检查功能测评

测评项	报文扩展头检查功能	
测评对象	防火墙设备	
测评方法	协议安全测试	
测评内容	支持报文扩展头检查功能	是 ☐ 否 ☐
	可以针对不同类型（逐跳选项、目的选项、路由首部、分片首部、认证首部、安全净荷封装）的扩展头进行识别, 并执行相应通过/丢包动作	是 ☐ 否 ☐

6.2.5 分片攻击防护能力测评

测评项	分片攻击防护能力	
测评对象	三层路由交换设备	
测评方法	协议安全测试	
测评内容	对 MTU（最大传输单元）小于 1280 字节的数据包, 进行丢弃处理（除非最后一个包）	是 ☐ 否 ☐
	针对三种扩展头：逐跳扩展头, 目的地址选项扩展头、路由扩展头, 出现在 IPv6 分片的数据部分, 进行丢弃处理	是 ☐ 否 ☐
	对于 IPv6 报文重组超时时间到达前, 由于分片包头未包含足够的重组信息导致无法完成重组的报文, 进行丢弃处理	是 ☐ 否 ☐
	对于分片重组后报文载荷长度大于 65535 字节的 IPv6 分片报文, 进行丢弃处理	是 ☐ 否 ☐

6.3 IPv6 DDoS 防护能力测评

6.3.1 基于 IPv6 的 Syn Flood 防护能力测评

测评项	基于 IPv6 的 Syn Flood 攻击防护能力	
测评对象	网络系统/抗 DDoS 设备	
测评方法	用仪表构建 IPv6SynFlood 攻击测试，检查被测网络/设备是否能够承受 IPv6 Syn Flood 攻击	
测评内容	检查被测网络/设备有 Syn Flood 防护机制	是□ 否 □
	被测网络/设备能够防范 IPv6 Syn Flood 攻击	是□ 否 □

6.3.2 基于 IPv6 的 UDP Flood 防护能力测评

测评项	基于 IPv6 的 UDP Flood 攻击防护能力	
测评对象	网络系统/抗 DDoS 设备	
测评方法	用仪表构建 IPv6 UDP Flood 攻击测试，检查被测网络/设备是否能够承受 IPv6 UDP Flood 攻击	
测评内容	检查被测网络/设备有 UDP Flood 防护机制	是□ 否 □
	被测网络/设备能够防范 IPv6 UDP Flood 攻击	是□ 否 □

6.3.3 基于 IPv6 的 ICMP Flood 防护能力测评

测评项	基于 IPv6 的 ICMP Flood 攻击防护能力	
测评对象	网络系统/抗 DDoS 设备	
测评方法	用仪表构建 IPv6ICMPFlood 攻击测试，检查被测网络/设备是否能够承受 IPv6 ICMP Flood 攻击	
测评内容	检查被测网络/设备有 ICMP Flood 防护机制	是□ 否 □
	被测网络/设备能够防范 IPv6 ICMP Flood 攻击	是□ 否 □

6.4 安全配置测评

6.4.1 日志告警安全测评

测评项	日志告警安全	
测评对象	网络设备/安全设备	
测评方法	检查网络单元中基础网络设备(交换机、路由器、负载均衡等)和安全设备的(防火墙等)的基线配置	

测评内容	设备应配置日志功能，对用户登录进行记录，记录内容包括用户登录使用的账号，登录是否成功，登录时间，以及远程登录时，用户使用的 IPv6 地址	是 ☐ 否 ☐
	设备应配置日志功能，记录用户对设备的操作，包括但不限于以下内容：账号创建、删除和权限修改等操作。记录需要包含用户账号，操作时间，操作内容以及操作结果	是 ☐ 否 ☐
	设备应配置日志告警功能，对与设备相关的攻击事件进行告警	是 ☐ 否 ☐

6.4.2 安全策略配置测评

测评项	安全策略配置	
测评对象	网络安全设备	
测评方法	检查网络单元中网络安全设备(防火墙、IDS/IPS 等)基线配置	
测评内容	支持 IPv6 五元组安全策略功能	是 ☐ 否 ☐
	可以针对 IPv6 报文的五元组(源 IPv6 地址，目的 IPv6 地址，源端口，目的端口，协议)进行识别，并执行相应通过/丢包动作	是 ☐ 否 ☐
	所有防火墙在配置访问规则时，最后一条默认必须是拒绝一切流量	是 ☐ 否 ☐
	检查安全设备是否开启了针对 IPv6 地址相关的安全策略，是否针对 ICMPv6 进行了安全控制，并放通网络中需要使用的 ICMPv6 报文	是 ☐ 否 ☐
	可以针对不同 ICMPv6 报文类型(消息类型、消息码)进行识别，并执行相应通过/丢包动作	是 ☐ 否 ☐
	检查安全设备是否开启防暴力破解功能，能够针对攻击者使用的 IPv6 地址或其前缀头进行限制	是 ☐ 否 ☐

6.5 漏洞扫描测评

6.5.1 系统/WEB 漏扫工具测评

测评项	系统/WEB 漏洞扫描工具功能	
测评对象	系统/WEB 漏洞扫描工具	
测评方法	检查系统/WEB 漏扫工具功能；	
测评内容	系统漏洞扫描工具是否支持 IPv6，可对 IPv6 地址进行扫描	是 ☐ 否 ☐

	系统漏洞扫描工具是否支持 IPv6 漏洞特征库如 CVE、CNVD、BugTraq 等	是 ☐ 否 ☐
	WEB 漏洞扫描工具是否支持 IPv6，可对 IPv6 地址进行扫描	是 ☐ 否 ☐
	WEB 漏洞扫描工具是否支持 IPv6 漏洞特征库如 CVE、CNVD、BugTraq 等	是 ☐ 否 ☐

6.5.2 系统漏洞测评

测评项	系统漏洞情况	
测评对象	设备/系统	
测评方法	使用系统漏扫工具对核心设备/系统进行漏洞扫描	
测评内容	主要核心设备/系统是否存在可利用的漏洞	是 ☐ 否 ☐

6.5.3 Web 漏洞测评

测评项	WEB 漏洞情况	
测评对象	网站	
测评方法	使用 Web 漏扫工具对网站进行漏洞扫描	
测评内容	是否支持检测基于 IPv6 地址网页中 SQL 注入、cookies、XSS 等攻击	是 ☐ 否 ☐
	网站是否具有相关防范措施	是 ☐ 否 ☐

6.5.4 端口开放性检测

测评项	端口开放性	
测评对象	网络设备	
测评方法	使用端口扫描工具扫描核心设备	
测评内容	检查核心网设备端口扫描工具报告,提供端口开放报告,端口开放最小化,没有不应该开启的端口(如: 21, 23 等)	是 ☐ 否 ☐
	检查安全设备端口扫描工具报告,提供端口开放报告,端口开放最小化,没有不应该开启的端口(如: 21, 23 等)	是 ☐ 否 ☐
	检查路由设备是否仅对可信主机开放端口,提供端口开放报告,非可信主机限制端口访问	是 ☐ 否 ☐

6.6 组网安全测评

6.6.1 网络隔离测评

测评项	网络隔离		
测评对象	网络		
测评方法	1. 检查是否有网络安全域划分方案 2. 核实网络安全域划分方案落实情况		
测评内容	检查被测网络是否有明确的 IPv6 网络安全域划分方案	是 ☐	否 ☐
	检查 IPv6 网络安全域划分方案是否在网络中进行正确实施	是 ☐	否 ☐

6.6.2 网络拓扑测评

测评项	网络拓扑安全		
测评对象	网络		
测评方法	1. 核实网络拓扑情况，并查看交换机路由器配置信息，核实拓扑图与实际网络是否相符 2. 核实相关设备部署情况，查看网络拓扑图，核实网络拓扑及相关设备部署符合有关标准对组网安全要求 3. 核实采用何种手段对主要网络设备进行运行状态监控，查看设备状态监控措施是否满足安全要求		
测评内容	拓扑图与实际网络是否一致	是 ☐	否 ☐
	网络拓扑及相关设备部署是否符合有关标准对组网安全的要求	是 ☐	否 ☐
	是否对主要网络设备进行状态监控	是 ☐	否 ☐